

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
	☐	Least Privilege NO
☐	☐	Disaster recovery plans NO
☐	☐	Password policies YES
☐	☐	Separation of duties NO
☐	☐	Firewall YES
☐	☐	Intrusion detection system (IDS) NO
☐	☐	Backups NO
☐	☐	Antivirus software YES
☐	☐	Manual monitoring, maintenance, and intervention for legacy systems YES
	☐	Encryption NO
☐	☐	Password management system NO
☐	☐	Locks (offices, storefront, warehouse) YES
☐	☐	Closed-circuit television (CCTV) surveillance YES

- ● Fire detection/prevention (fire alarm, sprinkler system, etc.) YES

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
	●	Only authorized users have access to customers’ credit card information. NO Only All Employees Currently Have Access to Internally Stored Data.
●	●	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. NO (Data is stored locally in an unencrypted internal database).
●	●	Implement data encryption procedures to better secure credit card transaction touchpoints and data. NO NO (Encryption is not currently utilized for payment data).
●	●	Adopt secure password management policies. NO (Password policy requirements are nominal and no password manager is used).

General Data Protection Regulation (GDPR)

Yes	No	Best practice
	●	E.U. customers’ data is kept private/secured. NO (Customer PII/SPII is stored unencrypted and accessible to all staff).
●	●	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. YES (The IT department established a plan to notify E.U. customers within 72 hours).
●	●	Ensure data is properly classified and inventoried. NO (IT needs resources to identify and classify existing assets)

-
- Enforce privacy policies, procedures, and processes to properly document and maintain data.

YES (Privacy policies and procedures are developed and enforced among employees).

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
	●	User access policies are established.
		NO (Least privilege and separation of duties policies have not been implemented).
●	●	Sensitive data (PII/SPII) is confidential/private.
		Sensitive data (PII/SPII) is confidential/private.\$\$\rightarrow\$\$
●	●	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
		YES (The IT department has integrated controls to ensure data integrity).
●	●	Data is available to individuals authorized to access it.
		YES (The IT department has ensured system and data availability).

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Recommendations for Botium Toys:

1. Implement Access Controls: Enforce Least Privilege and Separation of Duties to restrict access to sensitive customer data and cardholder information.
2. Encrypt Sensitive Data: Implement data encryption for credit card transactions and PII/SPII stored in local databases to meet PCI DSS and GDPR compliance.
3. Establish Business Continuity Plans: Develop a formal Disaster Recovery Plan (DRP) and schedule regular backups of critical data.
4. Improve Password Security: Deploy a centralized password management system update policies to enforce stronger password complexity.
5. Deploy Threat Detection: Install an Intrusion Detection System (IDS) to monitor the network for anomalous or malicious traffic.